

Ruta recomendada para un MVP financiero regional

Sprint 1 de identidad y experiencia web, más el primer tramo de elegibilidad regional y KYC para Sprint 2.

Recomendación principal

Primero construir una experiencia de registro segura y mínima. Después, en una etapa separada, validar identidad y residencia regional antes de permitir una solicitud de crédito. No usar el registro como sustituto de KYC ni lanzar préstamos reales hasta cerrar los gates legales, regulatorios, de riesgo y operación.

Documento para inversión y dirección

Fecha de elaboración: 3 de septiembre de 2026. Moneda de referencia: USD. Las cifras son presupuestos orientativos, sin impuestos, costos de personal, capital de préstamo, comisiones de pagos ni cotizaciones comerciales de KYC/buró. Deben validarse al contratar.

Cómo leerlo

Cada bloque responde tres preguntas: qué se necesita, qué tecnología usar y qué decisión debe aprobarse antes de pasar a producción. El informe distingue el MVP demostrable del producto que realmente puede operar y prestar dinero.

1. Decisión de negocio y capacidad objetivo

San Martín Finanzas debe operar como una plataforma regional de confianza: la prioridad no es crecer rápido sin control, sino demostrar un proceso claro, seguro, auditable y legalmente habilitado.

Escenario	Base poblacional	Cuentas registradas	MAU estimados*	Qué exige
Piloto: 1%	943,582	9,436	3,300	Arquitectura simple, proveedor de identidad y soporte manual controlado.
Lanzamiento inicial: 5%	943,582	47,179	16,500	Base administrada, monitoreo, recuperación probada, KYC y colas de revisión.
Crecimiento: 10%	943,582	94,358	33,000	Alta disponibilidad razonable, protección antifraude, operación y cumplimiento maduros.

*MAU = usuarios activos mensuales. Para el modelo se asume que 35% de las cuentas registradas está activo durante un mes. La proyección 2025 de INEI para San Martín es 943,582 personas; debe actualizarse al elaborar el plan comercial definitivo.

Principio para inversores

La plataforma puede soportar decenas de miles de usuarios con servicios administrados. El cuello de botella real no será Next.js ni Cognito: serán la habilitación legal, la calidad de KYC, el motor de riesgo, la atención de excepciones y el capital para los préstamos.

Objetivo por fases

Fase	Resultado	No hacer todavía
1. Demostrable	Home y pantallas de autenticación con diseño aprobado; previews para inversión.	No recoger DNI, dirección o documentos si no son necesarios para el demo.
2. MVP controlado	Cuenta real, contacto verificado, sesión segura y trazabilidad mínima.	No aprobar ni desembolsar crédito por reglas inventadas.
3. Elegibilidad	KYC, residencia regional y revisión de evidencias antes de permitir solicitud.	No decidir con IP, GPS o una autodeclaración como única prueba.
4. Operación crediticia	Solicitud, evaluación, contrato, desembolso, pagos y cobranza aprobados.	No salir sin opinión legal/regulatoria, modelo de riesgo y operación definida.

2. Arquitectura recomendada

Mantener el monolito modular ya decidido en el repositorio. No hace falta crear microservicios para el MVP. La seguridad se concentra en servicios administrados y límites claros.

Capa	Recomendación	Alternativa y momento de cambio
Web y BFF	Next.js en Vercel Pro. El BFF guarda tokens en servidor y envía al navegador solo una cookie segura.	AWS Amplify o CloudFront/Next.js si se requiere centralizar todo en AWS. Vercel es mejor para velocidad de frontend inicial.
Identidad	AWS Cognito User Pool con Authorization Code + PKCE. Nivel Essentials para experiencia moderna; correo como canal inicial recomendado.	Lite baja el costo y sirve con contraseña. Auth0/Clerk pueden ser más rápidos de integrar pero cambian el proveedor aprobado y suelen subir de precio.
API	Spring Boot modular: identity, customer, eligibility, audit y shared. Desplegar primero en AWS App Runner; pasar a ECS Fargate si se necesita red privada y control fino.	Render/Railway para demo técnico, no recomendados como destino final de un producto financiero.
Datos	PostgreSQL administrado (RDS) + Flyway. Redis administrado solo cuando haya sesiones server-side distribuidas.	Aurora PostgreSQL cuando la carga y disponibilidad justifiquen el costo.
Archivos KYC	S3 privado con cifrado KMS, URLs de carga temporales, antivirus, retención y borrado definidos.	Nunca guardar imágenes/documentos en PostgreSQL ni en Vercel.
Observabilidad	CloudWatch + Sentry. Alertas de errores, accesos anómalos y costos.	Datadog/New Relic para operación más compleja; evaluar cuando haya equipo de operaciones.
Entrega	GitHub Actions: lint, tests, build, escaneo de dependencias y preview Vercel por pull request.	GitLab CI u otro proveedor solo si el gobierno corporativo lo exige.

Límite de seguridad

El navegador no debe recibir access tokens ni refresh tokens. Cognito maneja credenciales; Next.js maneja sesión web; Spring Boot autoriza acciones y PostgreSQL guarda solo datos de negocio. Esta separación ya coincide con los ADR del proyecto.

3. Sprint 1: lo que debe quedar listo

El Sprint 1 prepara identidad digital, no identidad civil. Por tanto, se debe pedir solo lo necesario para crear una cuenta y comprobar que un contacto funciona.

Especificación	Qué pedir / hacer	Servicio o herramienta	Gate antes de producción
Home	Propuesta clara, CTA a registro e ingreso, enlaces legales y contacto. Responsive y accesible.	Figma aprobado, Next.js, Vercel Preview, Playwright y Lighthouse.	Contenido, términos, privacidad y canales de atención aprobados.
Registro	Correo, contraseña, aceptación separada de términos/privacidad. Celular solo si hay razón aprobada.	Cognito, SES para correo, BFF, Spring audit.	Campos exactos, política de contraseña, textos de consentimiento y retención aprobados.
Verificación	Código por correo; reenvío, vencimiento y límites. Mensajes genéricos.	Cognito + SES. SMS solo como segunda fase o canal alternativo.	Canal, duración, intentos, reenvío y tasa de fraude definidos.
Login y logout	Correo y contraseña; sesión opaca; cierre invalida sesión.	Cognito OIDC, Next.js BFF, Redis si hay varias instancias.	TTL de sesión, CSRF, cookies y manejo de dispositivo definidos.
Recuperación	Solicitud por correo sin revelar si la cuenta existe; nueva contraseña segura.	Cognito + SES; eventos de seguridad en Spring.	Mensajes, límites, expiración y soporte al usuario aprobados.
Auditoría	Registrar evento, fecha, resultado y referencia técnica; no guardar secretos ni OTP.	PostgreSQL audit, CloudWatch, Sentry.	Retención, acceso a logs y protocolo de incidentes definidos.

Decisión de datos en registro

Recomendación: no pedir DNI, dirección, distrito, foto de documento, ingresos ni datos de familia en el registro. Es información más sensible y cambia el riesgo de privacidad. Debe solicitarse solo cuando la persona decide pasar a una evaluación de crédito, con finalidad clara y consentimiento/aviso de privacidad adecuado.

Resultado esperado de Sprint 1
Una persona puede crear una cuenta, verificar su correo, ingresar, cerrar sesión y recuperar su acceso. Aún no se puede afirmar que vive en San Martín, que es quien dice ser o que califica para un crédito.

4. Primer tramo de Sprint 2: elegibilidad regional y KYC

La regla “solo personas de San Martín” debe ser una regla de negocio versionada y explicable. No debe depender de una sola señal técnica.

Paso	Qué se hace	Evidencia o señal	Resultado
1. Declaración	La persona indica su domicilio, provincia y distrito de una lista oficial controlada.	Dirección declarada + ubigeo.	Pre-filtro: puede iniciar onboarding, no es aprobación.
2. Identidad	Se verifica DNI y que la persona viva es la titular, mediante canal autorizado o proveedor contratado.	Consulta autorizada RENIEC y/o documento + prueba de vida.	Identidad validada o caso para revisión.
3. Residencia	Se contrasta domicilio declarado con evidencia reciente bajo una política aprobada.	Recibo/constancia admitida, fecha, dirección y ubigeo.	Elegible, no elegible o revisión manual.
4. Riesgo antifraude	Se evalúan inconsistencias, repetición de dispositivo, intentos y patrones.	Señales técnicas y de proveedor, nunca una sola señal automática.	Continuar, pedir evidencia adicional o revisar.
5. Auditoría	Se guarda versión de regla, resultado, motivo y evidencia mínima necesaria.	Registro de decisión y trazabilidad.	Decisión explicable y revisable.

Cómo diseñar la regla regional

Crear una tabla administrable de ubigeos elegibles de San Martín y una política de evidencia. La regla puede decir: “residente confirmado” solo cuando la dirección declarada pertenece a un ubigeo habilitado y la evidencia aceptada coincide o fue aprobada por un revisor autorizado. GPS, IP, operador móvil o geolocalización del navegador sirven solo como señales secundarias con aviso y consentimiento; no como prueba de residencia.

Servicios posibles

Necesidad	Opción recomendada	Opción alternativa	Nota de inversión
Validar identidad	Convenio/integración autorizada con RENIEC para persona jurídica.	Proveedor KYC comercial con cobertura peruana y contrato de tratamiento de datos.	RENIEC informa que sus consultas para entidades requieren convenio, servidor y desarrollo API.
Documento + prueba de vida	Proveedor KYC especializado: pedir pilotos a Sumsb, Persona, MetaMap, Veridas u otro que demuestre cobertura de DNI peruano.	Revisión manual limitada para piloto, con doble control y SLA.	No asumir cobertura, tasa de aprobación ni precio sin prueba con DNI peruano.
Buró / evaluación	Contratar un buró autorizado y definir finalidad, base legal y explicabilidad con asesoría legal.	No usar buró en el piloto si aún no hay política de crédito aprobada.	Cotización comercial obligatoria; el precio y alcance no suelen ser públicos.
Dirección	Lista oficial de ubigeos + evidencia documental y revisión de excepción.	Proveedor de verificación de domicilio, si ofrece cobertura real local.	La dirección por DNI puede no reflejar residencia actual; definir política de vigencia.

5. Legal, privacidad y cumplimiento: gates que no se deben saltar

Importante

Este informe orienta decisiones de producto y tecnología; no es asesoría legal, financiera ni regulatoria. Antes de otorgar dinero real se requiere una opinión formal de abogado peruano con experiencia en regulación financiera, consumidor, datos personales y prevención LA/FT.

Checklist mínimo antes de operar créditos

Gate	Qué debe estar resuelto	Dueño recomendado
Estructura y habilitación	Entidad legal, objeto social, modelo de fondeo, si la actividad requiere autorización/supervisión y obligaciones aplicables.	Abogado regulatorio + dirección.
Protección de datos	Inventario de datos, finalidad, base legal/consentimientos, avisos, derechos del titular, contratos con proveedores, medidas de seguridad, retención y eliminación.	DPO o responsable de privacidad + legal + tecnología.
KYC y fraude	Política de identidad, residencia, revisión humana, excepción, evidencias permitidas, anti-suplantación y conservación.	Riesgo + operaciones + legal.
LA/FT	Determinar condición de sujeto obligado, obligaciones UIF/SBS, enfoque de riesgos, oficial de cumplimiento y reportes si aplican.	Legal/compliance especializado.
Crédito y consumidor	Política de admisión, explicabilidad, contratos, información precontractual, reclamos, cobranza y tratamiento justo.	Riesgo + legal + negocio.
Ciberseguridad	Modelo de amenazas, MFA administrativo, backups, cifrado, pruebas de penetración, respuesta a incidentes y gestión de proveedores.	Seguridad + tecnología.

Normas y referencias peruanas a revisar con asesoría

Ley N.º 29733 y su Reglamento aprobado por D.S. N.º 016-2024-JUS para tratamiento de datos personales. La ANPD destaca la evaluación de impacto como medida preventiva. Para identidad, RENIEC indica que el servicio de consultas para instituciones parte de un convenio de suministro de información. La SBS/UIF publica quiénes son sujetos obligados y sus obligaciones; la condición exacta del modelo de negocio debe ser determinada por asesoría local. También se deben revisar obligaciones de protección al consumidor, contratos, tributación y el libro de reclamaciones según la operación final.

Diseño de privacidad por defecto

Separar tres expedientes: cuenta (Cognito), perfil de negocio (PostgreSQL) y evidencias KYC (S3/proveedor). Cada uno tiene acceso mínimo, cifra y retención propia. Registrar consentimiento no significa que se pueda reutilizar el dato para cualquier finalidad.

6. Seguridad y operación para un producto financiero

Control	MVP	Lanzamiento regional
Acceso de clientes	Contraseña fuerte, verificación por correo, rate limit y recuperación segura.	Agregar passkeys o MFA por aplicación autenticadora para acciones sensibles; evaluar Cognito Plus si el riesgo lo justifica.
Acceso interno	Roles mínimos, MFA obligatorio, cuentas individuales y revisión manual.	RBAC por permiso, segregación de funciones, revisiones periódicas y auditoría de accesos.
Secretos	Variables protegidas y AWS Secrets Manager; nunca Git, logs o capturas.	Rotación, cuentas separadas por entorno y políticas IAM de mínimo privilegio.
Datos y backups	RDS cifrado, backup automático, S3 privado y pruebas de restauración.	Multi-AZ, recuperación documentada, pruebas periódicas y retención aprobada.
Desarrollo	PRs, revisión, lint, tests, Dependabot y previews no públicas con datos reales.	SAST/DAST, gestión de vulnerabilidades, SBOM y revisión externa de penetración.
Incidentes	Alertas, responsable, runbook y canal de contacto.	Simulacros, tiempos objetivo, comunicación legal y trazabilidad post-incidente.

Protocolo técnico recomendado

HTTPS/TLS, OAuth 2.0 Authorization Code con PKCE, OIDC, cookies HttpOnly/Secure/SameSite, CSRF en mutaciones, validación de JWT en Spring Boot, cifrado en reposo con KMS, backups cifrados, logs sin PII sensible, OWASP ASVS como lista de control y OWASP Top 10 como mínimo de pruebas. Para APIs, documentar OpenAPI y versionar los contratos.

7. Costos orientativos

Son rangos mensuales de tecnología. No equivalen al presupuesto total del negocio. Los montos de KYC, buró, SMS y asesoría dependen de contratos, volúmenes, cobertura y exigencias regulatorias.

Partida	Demo / Sprint 1	MVP controlado	Lanzamiento regional inicial
Vercel Pro	USD 20-60 (1-3 asientos)	USD 40-100	USD 60-200 + uso
Cognito	USD 0 con menos de 10k MAU	USD 0-100	USD 100-500 aprox. según MAU y nivel
Correo SES	USD 1-10	USD 5-30	USD 20-150
API + PostgreSQL + Redis	USD 80-250	USD 250-900	USD 800-2,500
Logs, WAF, backups, monitoreo	USD 20-100	USD 80-350	USD 250-1,000

Partida	Demo / Sprint 1	MVP controlado	Lanzamiento regional inicial
KYC / identidad / buró	No contratar para demo	Piloto cotizado por verificación	Cotización comercial + equipo operativo
Total tecnológico orientativo	USD 120-420/mes	USD 375-1,480/mes + KYC	USD 1,230-4,350/mes + KYC/SMS/buró

Cómo se calcularon las referencias

Vercel Pro publica USD 20 por asiento/mes e incluye crédito de uso. Cognito Essentials ofrece 10,000 MAU gratis y luego USD 0.015 por MAU; por ejemplo, 16,500 MAU implican unos USD 97.50 de Cognito antes de extras. SES cobra USD 0.10 por 1,000 correos en el esquema a la carta. SMS se cobra por separado y suele ser más caro e incierto, por lo que el correo es el canal inicial recomendado.

Presupuesto único a reservar

Además de la plataforma, reservar una partida independiente para: asesoría legal/regulatoria, privacidad/DPIA, política de crédito, contratos, prueba de penetración externa, piloto KYC con muestras de DNI peruano, capacitación de operaciones y puesta en marcha. Un rango útil de planificación inicial es USD 15,000-50,000, pero solo una cotización profesional local puede convertirlo en presupuesto aprobado.

8. Plan de ejecución recomendado

Orden	Entregable	Decisión que se cierra
1	Completar el cuestionario funcional de Sprint 1 y convertirlo en especificación Markdown.	Datos de registro, canal de verificación, recuperación, sesión y consentimientos.
2	Auditar y aprobar Figma contra esa especificación.	Estados de error, accesibilidad, contenidos legales y flujos completos.
3	Preparar CI, previews Vercel, variables por entorno y monitoreo básico.	Cuenta, dominio, accesos internos y presupuesto de plataforma.
4	Implementar frontend visual y demostrarlo a inversión.	La demo se etiqueta como no transaccional si aún no hay backend real.
5	Implementar Cognito, BFF, sesiones, auditoría y API de customer.	Configuración real, política de seguridad y pruebas.
6	Hacer discovery legal/KYC y un piloto de proveedores.	Habilitación, proveedor de identidad, evidencias de residencia y excepciones.
7	Especificar Sprint 2 con contrato API, modelo de datos y reglas versionadas.	Qué es solicitud, elegibilidad, revisión y qué no es aún aprobación.
8	Prueba controlada sin dinero real o con el marco legal plenamente habilitado.	Métricas de fraude, tasa de abandono, soporte y viabilidad operativa.

Métricas que debe mirar inversión

Conversión Home a registro, porcentaje que verifica contacto, éxito de ingreso, recuperación exitosa, costo por cuenta activa, costo por verificación KYC, tiempo de revisión, tasa de fraude detectado, tasa de elegibilidad regional, reclamos, tiempo de respuesta y costo por solicitud. No medir solo número de registros.

Decisión recomendada hoy

Aprobar el camino, no la operación crediticia

Autorizar Sprint 1 con Cognito, correo, BFF y plataforma de previews. En paralelo, financiar el discovery legal y KYC. La decisión sobre préstamos reales debe ocurrir solo después de recibir el memo regulatorio, los contratos con proveedores, el modelo de riesgo y una prueba operativa controlada.

9. Fuentes consultadas

Precios y normas cambian. Revisar los enlaces antes de firmar cualquier contrato.

1. INEI, proyección de población departamental de San Martín (2025: 943,582):
<https://proyectos.inei.gob.pe/web/biblioineipub/bancopub/Est/Lib1039/libro.pdf>
2. Autoridad Nacional de Protección de Datos Personales, D.S. N.° 016-2024-JUS:
<https://www.gob.pe/institucion/anpd/normas-legales/6554453-n-016-2024-jus>
3. RENIEC, preguntas frecuentes de consultas en línea y convenio: <https://identidad.reniec.gob.pe/servicios-en-linea1>
4. SBS/UIF, relación de sujetos obligados y obligaciones:
<https://www.sbs.gob.pe/prevencion-de-lavado-activos/Sujetos-Obligados/Relacion-de-Sujetos-Obligados>
5. AWS Cognito Pricing: <https://aws.amazon.com/cognito/pricing/>
6. AWS SES Pricing: <https://aws.amazon.com/ses/pricing/>
7. Vercel Pricing: <https://vercel.com/pricing>
8. Repositorio San Martín Finanzas: Sprint 01 y ADR-005, ADR-007, ADR-011 y ADR-012.